

PET и FastTrack

Фреймворк внедрения технологии в рамки регуляторного поля

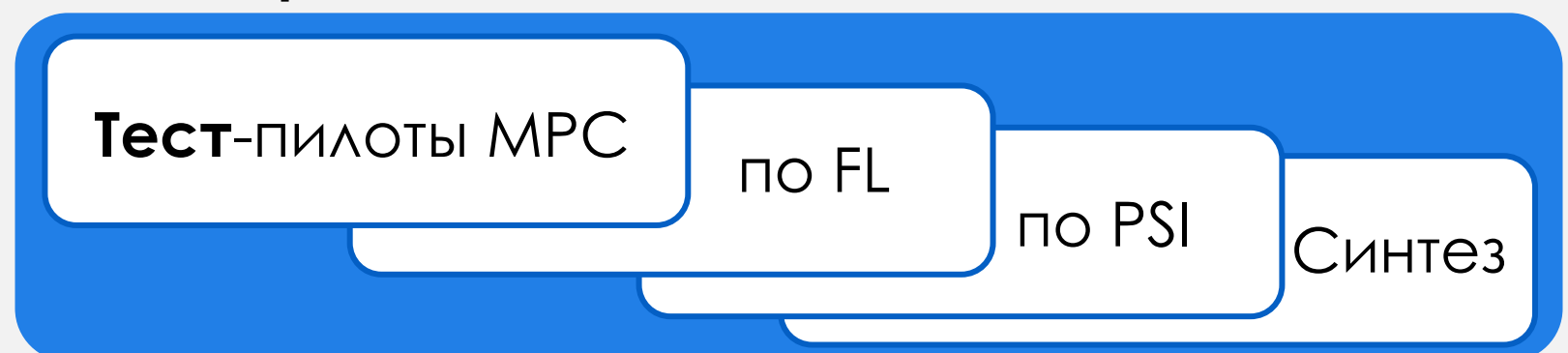
ПРОЕКТЫ ПО ТЕХНОЛОГИЯМ



Стадия 2. Техническое регулирование

Участники: АБД + ТК (профильный)

Артефакты: ПНСТ с описанием технологии и параметры рисков



Стадия 1. Технологическое тестирование

Участники: АБД + Партнер

Артефакты: Модель рисков приватности, виды угроз, список вероятных атак

ФРЕЙМ FAST TRACK

Технологическое соответствие продукта ПНСТ
по MPC | FI | PSI | Синтез

Стадия 3. Оценка соответствия

Участники: АБД + Владелец продукта +
Ведомство, уполномоченное
сертифицировать (например, ФСТЭК)

Артефакты: Сертификат соответствия
разработанному ПНСТ

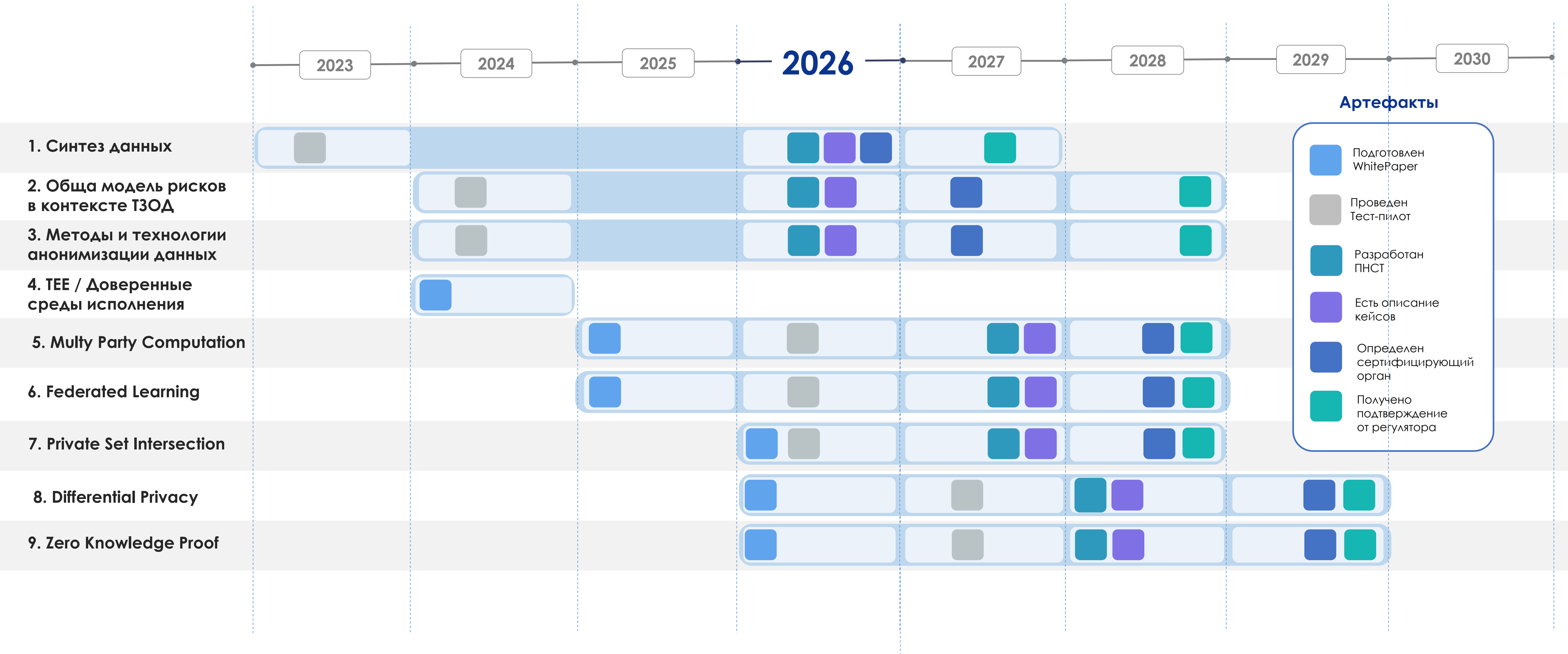
Регуляторные условия эксплуатации продукта
по MPC | FI | PSI

Стадия 4. Правовое подтверждение

Участники: АБД + Владелец продукта +
Регулятор (отраслевой)

Артефакты: Заключение регулятора
об эксплуатации продукта

РЕТ и федеративные вычисления



Предложения по регулированию обработки данных



Разработка сервиса
(продукта)
с применением
технологии повышения
конфиденциальности



Сертификация сервиса
(продукта)
на соответствие
нормативным
требованиям и
требованиям ПНСТ



Предоставление сервиса
(продукта) операторам
персональных данных
с целью обработки
данных



Обработка данных
на законном основании
в соответствии
с сертификатом (область
применения и условия
эксплуатации)

Порядок сертификации ТПК



Риски приватности

ОСНОВНЫЕ КОМПОНЕНТЫ

1

Риск представляет собой меру неопределенности и зависит от вероятности неблагоприятного события и его последствий (ущерба)

2

Приватность данных – это право субъекта данных (человека) контролировать какая информация о нем собирается и как она используется

3

Защита данных основана на классической триаде (конфиденциальности, целостности и доступности), приватность расширяет понятие конфиденциальности с позиции субъекта данных

4

Риски приватности возникают в следствии технических ограничений контролировать передачу информацию и наличие косвенных (статочных) следов приватной информации после её удаления

ОБМЕН
информацией



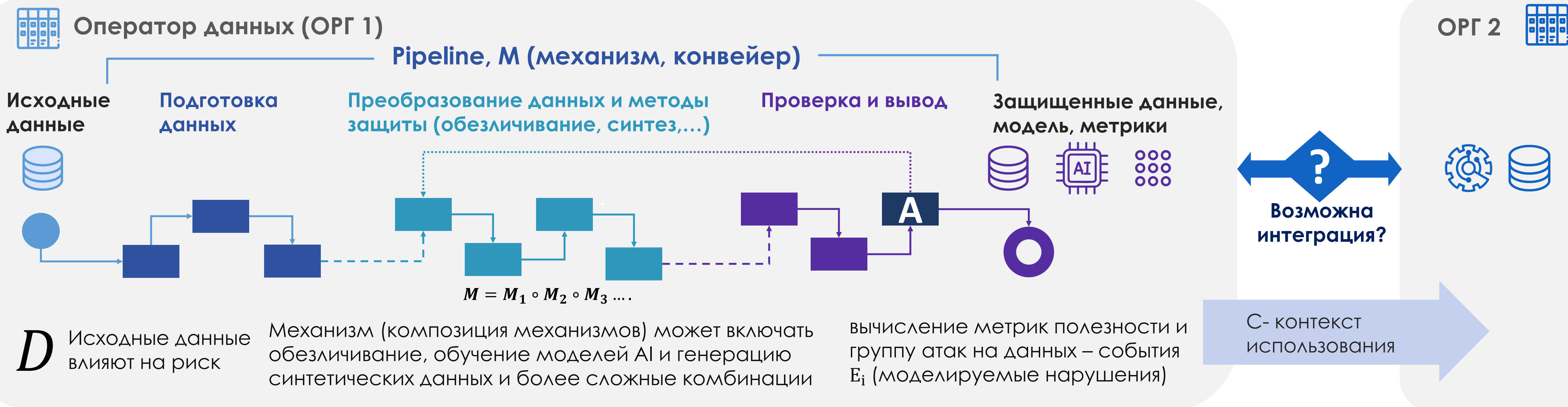
РИСК



**ПРИВАТНЫЕ
ДАННЫЕ**



Конвейер данных и его влияние на риск приватности



Приказ РКН № 140 требует провести «оценку достаточности» метода обезличивания. Но ни один нормативный акт не определяет критериев этой достаточности

Что остаётся открытым, если отсутствует измерения риска:

- Как измерить, что метод сработал?
- Как доказать регулятору достаточность обезличивания?
- Как сравнить два метода для одних данных?
- Как учесть риск ИИ-атак и связывания с внешними источниками?

Общая модель расчета риска

$$R = (\text{мат. ожидание ущерба}) = \mathbb{E}[L] = \sum_i P(E_i | D, M, C, A) \cdot L(E_i)$$

риск

Вероятность
Метод
Ущерб
Данные
Контекст
Событие i
Метод

Модель нарушителя

ТЕХНОЛОГИЧЕСКИЕ МОДЕЛИ

- ОБЕЗЛИЧИВАНИЕ
- СИНТЕЗ ДАННЫХ
- ФЕДЕРАТИВНОЕ ОБУЧЕНИЕ
- КОНФИДЕНЦИАЛЬНЫЕ ВЫЧИСЛЕНИЯ И DP

ПОДХОД К ДЕКОМПОЗИЦИИ РИСКА

СЦЕНАРНАЯ МОДЕЛЬ

Расчет риска
в зависимости
от варианта развития

CD-МОДЕЛЬ

Причинно-следственная
модель (что ведет
к утечке)

БАЙЕСОВСКАЯ МОДЕЛЬ

Изменение риска
во времени и вдоль
pipeline

АДДИТИВНАЯ МОДЕЛЬ

Риск как взвешенная
сумма атак
 $P = w_1 \cdot P_1 + w_2 \cdot P_2 + w_3 \cdot P_3$

КОМПОЗИТНАЯ МОДЕЛЬ

Для сложных конвейеров
данных или
многоуровневых
последствий

Каждая технология в PET имеет свои особенности и известные уязвимости.
Совокупность атак на технологию и всю цепочку – образует пакет Red Team («Красная Команда»)

Обезличивание

Обезличивание данных – наиболее доступный и наименее защищенный метод обеспечения приватности

Обезличивание персональных данных — это действия, в результате которых невозможно определить без использования дополнительной информации принадлежность персональных данных конкретному субъекту персональных данных.

АДДИТИВНАЯ МОДЕЛЬ

$$P = \sum_i w_i P_i$$

Рекомендуемые P_i :

P_{singl} — вероятность выделения записи

P_{link} — вероятность связывания

P_{inf} — вероятность вывода атрибута

Выделение записи: Модель k-Anonymity ($P_{singl} \sim \frac{1}{k}$)

Считаем по формальным моделям (k-анонимность, l-разнообразие, t-близость)

Связывание:

$$P_{link} = \frac{|\{r: \max_{z \in D_{ext}} sim(r, z) \geq \theta\}|}{|D|}$$

Моделируем с помощью CVPL (связь с источником) или метод Филлеги-Сунтера

Выделение атрибута:

$$Gain_{AIA} = 1 - \frac{H(S | O, A)}{H(S | A)}$$

Рассчитываем с помощью условной энтропии

МЕТОДЫ ОБЕЗЛИЧИВАНИЯ

С 1 сентября 2025 года действует приказ Роскомнадзора от 19.06.2025 N 140

1. Метод введения идентификаторов.
2. Метод изменения состава или семантики персональных данных
3. Метод перемешивания
4. Метод декомпозиции
5. Метод преобразования массива персональных данных

ТЕХНИКИ: обобщение, добавление шума, подавление записей, маскировка, псевдонимизация

УЯЗВИМОСТИ /АТАКИ

- Повторная идентификация через квази-идентификаторы
- Связывание (linkage) с внешними данными
- Достройка или вывод атрибутов по группе или эквивалентному классу
- Раскрытие редких комбинаций
- Восстановление через ключ псевдонимизации
- Связывание при повторных публикациях
- Выделение субъекта в малых группах
- Обратимость при слабой токенизации

Синтез данных

Синтез данных обеспечивает баланс между качеством и защищенностью с использованием статистики и генеративного ИИ

Синтетические данные — данные, искусственно созданные для имитации формата и свойств реальных данных, но которые не соответствуют напрямую каким-либо реальным объектам.

ОБЩАЯ МОДЕЛЬ -
ВЕКТОР

$$\mathbf{R}_{synt} = (R_{mem}, R_{link}, R_{AIA}, R_{MIA}, R_{group}, R_{access})$$

АДДИТИВНАЯ
МОДЕЛЬ

$$R_{synt} = w_{mem} \cdot R_{DCR} + w_{mi} \cdot \max(0, 2 \cdot AUC_{mia} - 1) + w_{link} \cdot P_{link} + w_{AIA} \cdot Gain_{AIA} + w_{pa} \cdot \rho(FI)$$

Запоминание
(выделение):

$$R_{DCR} = |\{x_{synt} : DCR(x_{syn}) < \theta\}| / |D_{syn}|$$

Считаем с использованием
DCR/NDDR

Связывание:

$$R_{link} = \frac{|\{r : \max_{z \in D_{ext}} sim(r, z) \geq \theta\}|}{|D|}$$

Моделируем с помощью
CVPL (связь с источником)

Членство:

$$Risk_{MIA, AUC} = \max(0, 2 \cdot AUC_{MIA} - 1)$$

Моделируем с помощью
теневых моделей на основе
уверенности

Выделение
паттернов:

$$Risk_{pattern} = \rho(FI_{real}, FI_{synt})$$

На основании корреляции ρ
и векторов feature importance FI

ПОДХОДЫ К СИНТЕЗУ

ПНСТ «Синтез Данных»

1. ML/генеративная синтетика (GAN, VAE, LLM-based) – табличные данные, контролируемая полезность
2. Статистическая синтетика (copula, Bayesian networks, marginal models)
3. DP-базированная синтетика (DP-MST, DP-Copula, noisy marginals)

Синтез данных образует сложные конвейеры, в которых могут проявляться уязвимости на уровне данных и моделей ИИ

УЯЗВИМОСТИ /АТАКИ

- Запоминание (memorization) отдельных записей;
- Ближайшие соседи, слишком похожие на реальные записи;
- Атаки на членство (membership inference): была ли запись в обучающем наборе генератора
- Связывание linkage с внешними источниками
- Вывод атрибутов (attribute inference)
- Раскрытие редких паттернов и малых групп
- Повторная генерация с исчерпанием бюджета приватности (privacy budget)

Федеративное обучение



Федеративное обучение (FL) снижает риски за счет отказа от обмена исходными данными и совместным обучением модели

Федеративное обучение бывает: горизонтальным (HFL) – участники имеют одинаковые признаки; вертикальным (VFL) – имеют разные признаки и объекты; трансферным (FTL) – частично пересекаются и признаки и объекта. В VFL нужен этап согласования объектов – часто через PSI.

ОБЩАЯ МОДЕЛЬ
– ВЕКТОР

$$\mathbf{R}_{FL} = (R_{client}, R_{update}, R_{aggr}, R_{model}, R_{inf}, R_{govern})$$

СЦЕНАРНАЯ
МОДЕЛЬ

$$R_{FL} = \sum_c \pi(c) \cdot P_{observe}(c) \cdot P_{infer}(c) \cdot S(c) \cdot (1 - M_c)$$

Разложение наблюдаемости (градиенты, метки) Покрытие сценария с мерами снижения риска, от 0 до 1

Априорная вероятность сценария c Вывод информации из модели Тяжесть сценария (вес)

Разложение наблюдаемости:

$$\pi(c) = P(\text{topology}) \cdot P(\text{role} \mid \text{topology}) \cdot P(\text{adversary} \mid \text{role}, C) \cdot P(\text{access} \mid \text{stage}, C)$$

Разложение успешного вывода:

$$P_{infer}(c) = 1 - \prod_{a \in \mathcal{A}_c} (1 - \rho_a(c) \cdot P_{\text{success}}(a \mid c))$$
$$P_{GLA} = P(G \text{ observable}) \cdot P(\hat{X} \approx X \mid G, A)$$

Расчет для обновления:

$$I_{struct} = \log_2 |\Omega_{before}| - \log_2 |\Omega_{after}|$$

Задается экспертно и анализируется по вкладу

На практике взвешенная сумма по атакам (например, по Gradient Leakage Attack - GLA)

Здесь для VFL Ω – множество возможных состояний

ПОДХОДЫ К FL

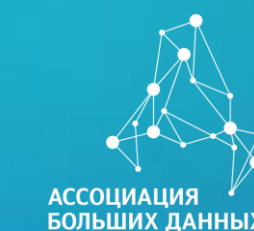
1. HFL: FedSGD, **FedAvg**, FedProx, SCAFFOLD, FedNova
2. VFL: **SecureBoost**, SecureBoost+, VFL Logistic Regression, VFL Neural Nets
3. Tree-based FL: (**SecureBoost**, FederBoost, SecureBoost+
4. Split Learning / SplitFL: SplitNN, SplitFed, VFL-NN
5. Clustered / Mixture FL: Clustered FL, IFCA, mixture-of-experts FL

Хотя сами данные не переносятся, градиенты обучения, входы и выходы требуют защиты с использованием гомоморфного шифрования или DP

УЯЗВИМОСТИ /АТАКИ

- Утечка градиентов (gradient leakage) и reconstruction
- Раскрытие меток (label inference) и attribute inference
- Атаки на членство (membership inference) по модели или обновлениям, а также инверсия модели
- Утечки через служебные поля, веса, пакеты метаданных (batch metadata)
- Утечки через выравнивание (PSI alignment)
- Сговор участников

Конфиденциальные вычисления



Методы основанные на криптографии схемы распределенных вычислений с поддержкой приватности за счет криптографии и иных мат. моделей

Secure Multi-Party Computation (SMPC) позволяет нескольким сторонам совместно вычислить функцию над их входами без раскрытия входов друг другу за пределами результата и разрешенных утечек протокола. Private Set Intersection (PSI) позволяет сторонам вычислить пересечение множеств без раскрытия непересекающихся элементов.

ОБЩАЯ МОДЕЛЬ
– ВЕКТОР

$$\mathbf{R}_{CC} = (R_{input}, R_{protocol}, R_{metadata}, R_{output}, R_{collis}, R_{op})$$

СЦЕНАРНАЯ
МОДЕЛЬ

$$R_{CC} = \sum_c \pi(c) \cdot RI(c) \cdot (1 - M_c)$$

Покрытие сценария с мерами
снижения риска, от 0 до 1

Априорная вероятность сценария c Тяжесть сценария (вес)

PSI на низко-
энтропийных ID:

$$H(X) = \log_2 |\mathcal{X}|$$
$$T_{\text{bruteforce}} = \frac{|\mathcal{X}| \cdot t_{\text{op}}}{P_{\text{parallel}}}$$

$\mathcal{X}$ - домен идентификаторов
(телефоны), t_{op} – время операторов

Крипто-атака:

$$\Phi_{\text{crypto}}^{PHE} = \frac{C \times T}{2^\lambda}$$

C - вычислительная мощность, T –
время, доступное для атаки, λ -биты
безопасности

DP:

$$L(o) = \ln \frac{\Pr[M(D) = o]}{\Pr[M(D') = o]} \quad Adv_{\text{MIA}} \lesssim \frac{e^\epsilon - 1}{e^\epsilon + 1} + \delta$$

Атаки на DP связаны с функцией
потери приватности или истощением
бюджета

ПОДХОДЫ

1. Совместные защищенные вычисления (SMPC/MPC, secret sharing, garbled circuits, oblivious transfer, secure aggregation, private aggregation).
2. Приватное сопоставление данных (PSI, threshold PSI, OPRF-based PSI, private join and compute, privacy-preserving record linkage)
3. Вычисления над зашифрованными данными (HE, PHE, searchable encryption)
4. Доказательства без раскрытия (ZKP, zk-SNARK, zk-STARK, range proofs, set membership proofs)
5. Доверенные среды (TEE, confidential VMs)
6. Контроль раскрытия информации (DP, DG-SGD, shuffle PATE, DP)

УЯЗВИМОСТИ /АТАКИ

- Атаки на входы и выходы (исходные данные, результат вычисления)
- Утечка метаданных (размеры наборов, число участников, структура раундов)
- Структурные данные (совпадения классов, размер пересечения, устойчивый токен, восстановление низко-энтропийных записей)
- Утечка по побочным каналам (тайминги, память, кэш, размер сообщений, сетевые шаблоны)
- Сговор участников



Методы конфиденциальных вычислений часто используются как крипто-примитивы и поддерживают другие методы. Криптография вносит наименьший риск в данные

ВЫВОДЫ

**Универсального решения не существует:
риски дают количественную оценку мер защиты, но зависят от качества модели**

1. Риск приватности не равен факту утечки данных.

Это вероятность того, что по данным, результату, модели, метаданным или артефактам обработки можно получить нежелательную информацию о субъекте, группе или бизнес-логике

2. Главный объект оценки — не метод, а сценарий обработки.

Один и тот же метод может быть допустимым в одном контексте и рискованным в другом. Важны данные, цель, роли сторон, доступы, внешние знания, повторное использование и результат

3. Большая часть риска живет вокруг технологии, а не внутри нее.

В практических PET-сценариях доминируют не только криптостойкость или математическая гарантия, а метаданные, выход результата, ключи, логи, роли, сговор, повторные запросы и управленческий вклад

4. Риск-модель — это инструмент принятия решения.

Ее цель не доказать абсолютную безопасность, а поддержать решение: можно использовать, можно с условиями, требуется доработка, нельзя использовать в данном сценарии. При этом значительную роль играет известный корпус атак (RED TEAM PACK)